

Cybersecurity Fundamentals

Module 1 – Introduction to Cybersecurity

What is Cybersecurity?

Cybersecurity is the practice of protecting an organization's information, systems, networks, applications, devices, and digital services from cyber threats, unauthorized access, misuse, damage, or disruption.

Cybersecurity is built on three pillars:

- **People** – Employees, customers, vendors, administrators.
- **Processes** – Policies, procedures, standards, incident response.
- **Technology** – Firewalls, antivirus, IAM, encryption, SIEM, EDR.

Cybersecurity is not only about preventing hackers. Its main purpose is to ensure that the business can operate securely and continuously.

As a GRC professional, you won't configure firewalls or investigate malware daily. Instead, you'll:

- Assess cyber risks.
- Develop security policies.
- Ensure compliance with regulations.
- Evaluate whether security controls are effective.
- Advise management on security decisions.
- Support audits and risk management.

To do that, you must understand what cybersecurity is protecting and why.

Information Security vs Cybersecurity

These terms are often used interchangeably, but they are different.

Information Security (InfoSec) protects all information, regardless of its form.

Information can exist as:

- Paper documents
- Emails
- Databases
- Cloud storage
- USB drives
- Verbal communication

Cybersecurity protects digital information and digital systems from cyber threats.

Cybersecurity is therefore a subset of Information Security.

Many standards such as ISO/IEC 27001 focus on Information Security, not only cybersecurity.

As a GRC professional, your responsibility is to protect information in every form.

Information Security is broader.

Cybersecurity is one part of Information Security.

GRC primarily manages Information Security.

Why Cybersecurity Matters

Organizations depend on technology for almost every business process. Cybersecurity ensures these processes remain secure, reliable, and available.

Weak cybersecurity can lead to:

- Financial losses
- Regulatory penalties
- Operational disruption
- Reputational damage
- Loss of customer trust
- Legal action

GRC professionals identify these risks and recommend controls to reduce them.

Cybersecurity is an investment in business resilience, not merely an IT expense.

While auditing ISO 27001,

You may encounter:

- Firewalls
- VPNs
- Active Directory
- IAM
- Cloud Storage
- Encryption
- Logging

You don't need to configure them.

But you must understand:

- What they are
- Why they exist
- What risks they address
- Which security controls they support

This is why cybersecurity is the foundation of GRC

Core Components of Cybersecurity

1. Network Security
2. Application Security
3. Information Security

4. Endpoint Security
5. Cloud Security
6. Identity and Access Management (IAM)
7. Security Operations
8. Governance, Risk & Compliance (GRC)

Information as an Organizational Asset

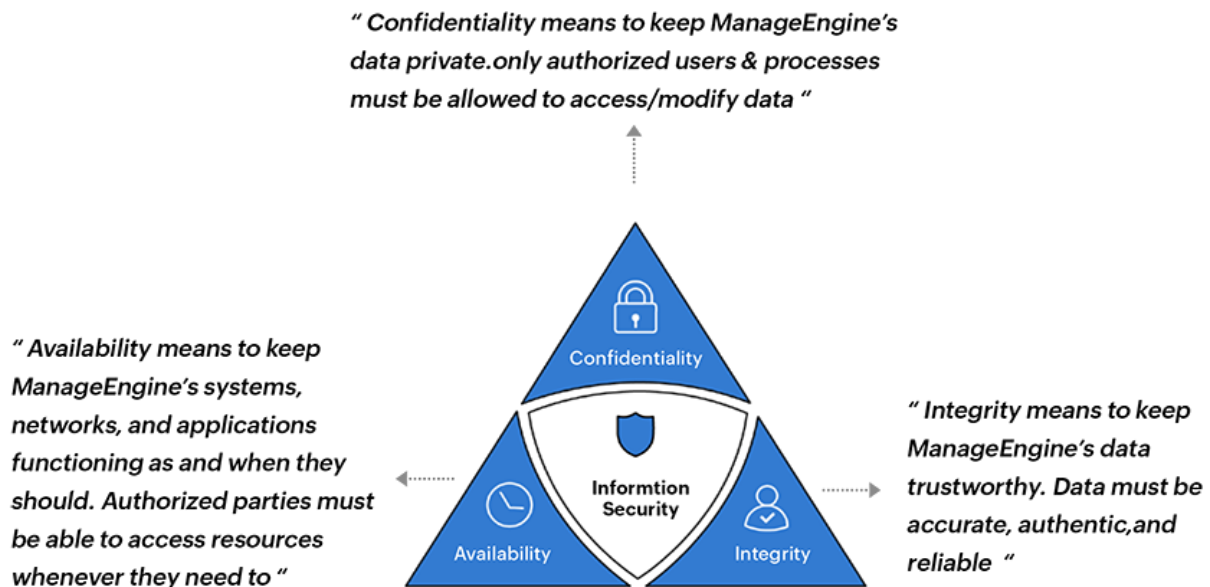
An asset is anything valuable to an organization.

Information is one of the most valuable organizational assets because it supports decision-making, operations, customer service, and competitive advantage.

Risk assessments begin by identifying assets.

If you don't know what information is valuable, you cannot determine what needs protection or prioritize security efforts.

Every organization has information assets, and not all assets have the same value or sensitivity.



CIA Triad

The **CIA Triad** is the fundamental model of Information Security.

It consists of:

Confidentiality – Information is accessible only to authorized individuals.

Integrity – Information remains accurate, complete, and unaltered unless changed by authorized persons.

Availability – Information and systems are accessible when needed by authorized users.

Most security controls, risk assessments, and compliance requirements ultimately support one or more elements of the CIA Triad.

Understanding it is essential for evaluating security risks and selecting appropriate controls.

Security Goals

Security Goals define what an organization wants to achieve through cybersecurity. They guide the design of security controls, policies, and procedures to protect business operations and information assets.

Confidentiality – Prevent unauthorized access to information.

Integrity – Ensure information remains accurate and unaltered.

Availability – Ensure systems and information are accessible when needed.

Authenticity – Verify that users, systems, and data are genuine.

Accountability – Ensure actions can be traced back to an individual or system.

Non-Repudiation – Prevent someone from denying an action they performed.

Organizations implement security controls to achieve these goals. Every policy, audit, and risk assessment ultimately evaluates whether these objectives are being met.

As a GRC professional, you'll use these goals to:

- Assess risks.
- Evaluate security controls.
- Understand audit findings.
- Recommend improvements.

Security Principles

Every security policy, control, and framework is based on these principles. Understanding them helps you understand *why* organizations implement specific controls.

Least Privilege

Users receive only the minimum access required to perform their job.

Need-to-Know

Information is shared only with individuals who require it.

Separation of Duties (SoD)

Critical tasks are divided among multiple people to reduce fraud and errors.

Defense in Depth

Multiple layers of security protect the organization so that failure of one control doesn't expose everything.

Secure by Design

Security should be incorporated during system design, not added afterward.

Default Deny

Access is denied unless explicitly granted.

Principle of Simplicity

Simpler systems are generally easier to secure and maintain.

Fail-Safe Defaults

Set systems to a secure state (like blocking access) if an error or crash happens.

Minimize Attack Surface

Keep systems simple and turn off extra features or open ports you do not use.

Zero Trust

Follow the rule of "never trust, always verify" for every user and device

Cybersecurity Domains

Cybersecurity is divided into specialized areas called domains. Each domain focuses on protecting a different part of the organization's environment.

A GRC professional doesn't need to master every domain but should understand their purpose.

During audits, risk assessments, or compliance reviews, you'll interact with teams from different domains. Understanding their responsibilities improves communication and decision-making.

Major cybersecurity domains include:

- Network Security
- Application Security
- Cloud Security
- Endpoint Security
- Identity & Access Management (IAM)
- Information Security
- Incident Response
- Security Operations (SOC)
- Governance, Risk & Compliance (GRC)
- Business Continuity & Disaster Recovery

Each domain contributes to the organization's overall security posture.

Cybersecurity Lifecycle



Cybersecurity is not a one-time activity where an organization installs antivirus software or configures a firewall and considers itself secure forever. Technology changes, business requirements evolve, and cyber threats become more sophisticated every day. Because of this, cybersecurity is treated as a continuous lifecycle that involves identifying risks, implementing controls, monitoring for threats, responding to incidents, recovering from disruptions, and continuously improving security. This lifecycle ensures that security remains effective throughout the organization's operations rather than becoming outdated over time.

The most widely accepted cybersecurity lifecycle consists of five stages:

Identify

- Identify business assets.
- Understand threats and vulnerabilities.
- Perform risk assessments.
- Maintain an asset inventory.

Protect

- Apply security controls.
- Train employees.
- Manage access.
- Encrypt sensitive information.

Detect

- Monitor logs.
- Detect unusual activities.
- Identify incidents quickly.

Respond

- Contain attacks.
- Investigate incidents.
- Notify stakeholders.
- Minimize business impact.

Recover

- Restore systems.
- Recover data from backups.
- Review lessons learned.
- Improve future security controls.

This cycle never ends. After recovery, organizations reassess risks and begin the process again.

Every GRC activity fits somewhere within this lifecycle. During risk assessments, you'll work in the Identify phase. When reviewing policies or security controls, you'll contribute to the Protect phase. During audits, you'll evaluate whether detection and response processes are

effective. After an incident, you'll help review what happened, identify compliance obligations, and recommend improvements.

Understanding this lifecycle helps you see cybersecurity as an ongoing management process rather than a collection of technical tools.

Governance Overview

Governance is the process through which an organization's leadership ensures that cybersecurity supports business objectives, manages risks effectively, complies with legal and regulatory requirements, and uses resources responsibly. Unlike technical teams that implement security controls, governance focuses on setting direction, defining expectations, making strategic decisions, and monitoring performance.

Governance answers questions such as:

- What level of cyber risk is acceptable?
- Which security policies should the organization implement?
- Who is responsible for security decisions?
- How will security performance be measured?
- Are we complying with applicable laws and standards?

Governance is primarily the responsibility of senior management and the Board of Directors. They establish the organization's security strategy, approve policies, define risk appetite, allocate budgets, and ensure accountability. Technical teams then implement these decisions through operational activities.

Think of governance as deciding what should be achieved, while management and technical teams determine how it will be achieved.

Governance is the core of GRC. Almost everything you'll study later—ISO/IEC 27001, Risk Management, NIST CSF, NIST RMF, audits, compliance, policies, standards, and executive reporting—is part of governance.

Governance includes:

- Defining security strategy.
- Developing policies and standards.
- Assigning roles and responsibilities.
- Establishing risk appetite.
- Monitoring security performance.
- Ensuring regulatory compliance.
- Supporting continuous improvement.

Security Culture

Security Culture is the collective mindset, attitude, values, and day-to-day behavior of everyone in an organization toward protecting information and technology. It reflects how seriously employees, management, and leadership take cybersecurity in their daily work. A strong security culture means employees do not follow security practices simply because policies require them—they understand why those practices exist and naturally make security-conscious decisions.

Technology alone cannot secure an organization. Even if an organization has advanced firewalls, antivirus software, encryption, and monitoring systems, a single employee clicking a phishing email or sharing confidential information can lead to a major security incident.

As a future GRC professional, Security Culture is highly important because governance is not only about creating policies—it is also about ensuring those policies are understood, accepted, and followed. During ISO/IEC 27001 audits, compliance assessments, and security reviews, you'll evaluate whether employees receive awareness training, understand their responsibilities, comply with policies, and report security incidents. A technically secure organization with poor security culture is still considered high risk.

Key Elements of Security Culture

1. Leadership Commitment

Security culture starts with senior management. Leadership must demonstrate that cybersecurity is a business priority by supporting security initiatives, approving policies, allocating budgets, and following security practices themselves. Employees are more likely to follow security rules when they see leadership doing the same.

2. Security Awareness

Employees should understand common cyber threats, organizational policies, and safe security practices. Awareness is developed through regular training, awareness campaigns, phishing simulations, newsletters, workshops, and communication.

3. Accountability

Every employee is responsible for protecting organizational information. Security responsibilities should be clearly defined so everyone understands their role in maintaining security.

4. Policy Compliance

Employees should consistently follow organizational security policies and procedures such as password policies, acceptable use policies, clean desk policies, and data handling procedures. Policies are valuable only when they are implemented in daily work.

5. Incident Reporting

Employees should immediately report suspicious emails, unusual system behavior, policy violations, or security incidents. Organizations should encourage reporting without creating fear of punishment for genuine mistakes, as early reporting helps reduce damage.

6. Continuous Learning

Cyber threats constantly evolve. Organizations should provide continuous security education through regular training, refresher sessions, phishing simulations, and updates on emerging threats to keep employees informed.

7. Shared Responsibility

Cybersecurity is not only the responsibility of the IT or Security department. Every department—including HR, Finance, Legal, Operations, and Senior Management—has specific responsibilities for protecting organizational information.

Characteristics of a Strong Security Culture

- Employees understand security policies.
- Security awareness training is conducted regularly.
- Management actively supports cybersecurity.
- Employees report suspicious activities immediately.
- Security is considered during daily decision-making.
- Policies are consistently followed across the organization.
- Continuous improvement is encouraged.

Characteristics of a Weak Security Culture

- Employees ignore security policies.
- Passwords are shared.
- Phishing emails are frequently clicked.
- Security incidents go unreported.
- Management gives low priority to cybersecurity.
- Employees believe cybersecurity is only IT's responsibility.

For a GRC professional, Security Culture is an administrative control that reduces organizational risk by influencing human behaviour. Even the best technical controls cannot compensate for a weak security culture, which is why auditors and compliance professionals treat it as a critical component of an effective Information Security Management System (ISMS).

Module 2 – Threat Landscape

Threats vs Vulnerabilities vs Attacks vs Risks

These four terms are the foundation of cybersecurity and GRC. Many beginners confuse them, but each represents a different stage in how a security incident occurs. Understanding their relationship is essential because almost every risk assessment, audit, ISO 27001 implementation, or compliance review revolves around these concepts.

A **Threat** is anything that has the potential to cause harm to an organization's information, systems, or operations. A threat does not necessarily cause damage by itself—it only has the capability to do so. Threats may come from hackers, malware, natural disasters, insider misuse, hardware failures, or human mistakes.

A **Vulnerability** is a weakness or flaw that can be exploited by a threat. Vulnerabilities may exist in software, hardware, business processes, configurations, or even employee behavior. A threat becomes dangerous only when it finds a vulnerability to exploit.

An **Attack** is the actual attempt to exploit a vulnerability. It is the action taken by a threat actor to compromise confidentiality, integrity, or availability.

A **Risk** is the possibility that a threat will successfully exploit a vulnerability and cause harm to the organization. Risk considers both the likelihood of an event occurring and the impact if it occurs.

This is probably the most important concept you'll learn before studying Risk Management. Every GRC activity begins with identifying:

- What are the threats?
- What vulnerabilities exist?
- What attacks could occur?
- What level of risk do they create?

Without understanding these four terms, you cannot perform a proper risk assessment or recommend effective security controls.

Threat Actors

A Threat Actor is any individual, group, or organization capable of causing harm to an organization's information systems. Not all threat actors have the same motivations. Some seek financial gain, others steal information, disrupt operations, conduct espionage, or simply cause damage.

Understanding threat actors helps organizations determine which threats are most relevant and what security controls are required.

As a GRC professional, you'll identify threat actors during risk assessments and threat modeling. Different industries face different threat actors. For example, banks are often targeted by cybercriminals, while government organizations may face nation-state attacks.

Common Threat Actors:

Cybercriminals

Financial motivation.

Steal money or data.

Nation-State Actors

Government-backed attackers.

Conduct espionage or sabotage.

Insiders

Employees, contractors, vendors.

May be malicious or accidental.

Hactivists

Politically or socially motivated.

Attack organizations to promote a cause.

Competitors

Attempt to steal intellectual property or business information.

Script Kiddies

Inexperienced attackers using publicly available tools.

Malware

Malware (Malicious Software) is any software intentionally designed to damage systems, steal information, disrupt operations, or provide unauthorized access to attackers. Malware is one of the most common cyber threats organizations face. It usually spreads through phishing emails, infected websites, malicious downloads, removable media, or software vulnerabilities. Malware can lead to data breaches, operational downtime, financial losses,

and regulatory violations. During audits and risk assessments, you'll evaluate whether organizations have appropriate controls to prevent, detect, and respond to malware.

Virus

Attaches to legitimate files.

Requires user action to spread.

Worm

Self-replicates automatically across networks.

Trojan

Appears legitimate but performs malicious actions.

Ransomware

Encrypts files and demands payment.

Spyware

Secretly collects user information.

Adware

Displays unwanted advertisements.

Rootkit

Hides malicious activity from users and security software.

Social Engineering

Social Engineering is the practice of manipulating people into revealing confidential information or performing actions that compromise security. Instead of attacking technology directly, attackers exploit human psychology such as trust, fear, curiosity, urgency, or helpfulness.

Most successful cyberattacks begin with some form of social engineering. GRC professionals evaluate awareness programs, security culture, and policies designed to reduce these risks.

Common Social Engineering Techniques:

- Phishing
- Vishing (Voice calls)
- Smishing (SMS messages)
- Pretexting
- Baiting
- Tailgating
- Impersonation

Phishing

Phishing is a specific type of social engineering attack in which attackers send fraudulent emails, messages, or websites that appear legitimate to trick victims into revealing sensitive information, downloading malware, or performing unauthorized actions.

The goal is to convince the victim that the communication comes from a trusted source such as a bank, employer, government agency, or service provider.

Phishing remains one of the leading causes of data breaches worldwide. Organizations invest heavily in awareness training because even advanced security technologies cannot completely eliminate phishing risks if employees are not vigilant.

As a GRC professional, you'll review phishing awareness programs, incident reporting procedures, and email security controls during audits.

Password Attacks

Passwords are the most common method of authentication, making them one of the primary targets for attackers. A password attack is any attempt to obtain, guess, crack, or steal a user's

password to gain unauthorized access to systems or data. Weak passwords, reused passwords, and poor password management significantly increase the likelihood of successful attacks.

Organizations reduce password-related risks by implementing strong password policies, Multi-Factor Authentication (MFA), account lockout mechanisms, password managers, and continuous user awareness.

Compromised credentials are one of the leading causes of data breaches. During audits and compliance assessments, GRC professionals evaluate password policies, authentication mechanisms, access management controls, and compliance with security standards like ISO 27001.

Common Password Attacks

Brute Force Attack

Dictionary Attack

Credential Stuffing

Password Spraying

Rainbow Table Attack

Keylogger

Insider Threats

An Insider Threat is a security risk that originates from someone who has authorized access to an organization's systems, information, or facilities. Unlike external attackers, insiders already possess legitimate access, making them more difficult to detect.

Insider threats are not always malicious. Many incidents occur because of negligence, mistakes, or lack of awareness rather than intentional misconduct.

Insider threats are particularly challenging because traditional security controls often trust authorized users. As a GRC professional, you'll assess access controls, user privileges, segregation of duties, monitoring, and employee awareness to reduce insider risks.

Network Attacks

Network attacks target an organization's network infrastructure to gain unauthorized access, intercept communications, disrupt services, or steal information. Since every organization depends on networks to connect users, systems, and cloud services, protecting network infrastructure is a critical part of cybersecurity.

Network attacks may target communication between devices, network services, or network availability.

Although GRC professionals don't configure firewalls or routers, they evaluate whether appropriate network security controls exist and whether they effectively reduce organizational risk.

Web Application Attacks

Web applications allow users to interact with organizational systems through browsers. Because they often process sensitive information such as customer data, financial transactions, and login credentials, they are common targets for attackers.

Web application attacks exploit weaknesses in application design, coding, authentication, or input validation.

Many modern organizations rely heavily on web applications. During audits and compliance

assessments, GRC professionals review secure development practices, vulnerability management, penetration testing reports, and application security controls.

Common Web Application Attacks

SQL Injection (SQLi)

Malicious SQL commands manipulate databases.

Cross-Site Scripting (XSS)

Malicious scripts execute in another user's browser.

Cross-Site Request Forgery (CSRF)

Tricks authenticated users into performing unintended actions.

Broken Authentication

Weak authentication allows unauthorized access.

Broken Access Control

Users gain access to resources they shouldn't.

Controls

- Input Validation
- Secure Coding
- MFA
- Regular Security Testing
- Patch Management
- Web Application Firewalls (WAF)

Advanced Persistent Threats (APT)

An Advanced Persistent Threat (APT) is a highly sophisticated, targeted cyberattack in which attackers gain unauthorized access to an organization's network and remain undetected for an extended period. Unlike ordinary attacks that seek quick results, APTs focus on long-term objectives such as espionage, intellectual property theft, or disruption of critical infrastructure.

APT attacks are commonly associated with nation-state groups or highly organized cybercriminal organizations.

Organizations in government, finance, healthcare, defense, and critical infrastructure face increased risk from APTs. GRC professionals evaluate security governance, monitoring capabilities, incident response readiness, and risk management strategies to reduce exposure.

Zero-Day Vulnerabilities

A Zero-Day Vulnerability is a software flaw that is unknown to the software vendor or has no available security patch. Attackers who discover these vulnerabilities before vendors release fixes can exploit them to compromise systems.

Because organizations have zero days to prepare before exploitation begins, these vulnerabilities are considered extremely dangerous.

Zero-day vulnerabilities create high-risk situations because organizations cannot immediately eliminate the weakness. GRC professionals monitor vulnerability management processes, patch management, risk assessments, and compensating controls until official fixes become available.

Emerging Threats (AI, Cloud, IoT & Supply Chain)

As technology evolves, new cyber threats continue to emerge. Organizations increasingly

rely on cloud computing, artificial intelligence, Internet of Things (IoT) devices, and third-party suppliers. While these technologies improve efficiency, they also introduce new security risks that organizations must manage.

Cybersecurity today extends beyond protecting internal systems—it also includes protecting cloud environments, connected devices, AI systems, and external business partners.

As a future GRC professional, you'll increasingly assess risks associated with modern technologies. Organizations now require governance, policies, and compliance programs specifically for cloud security, AI governance, IoT security, and third-party risk management.

AI Threats

- AI-generated phishing.
- Deepfakes.
- Prompt injection.
- Model manipulation.

Cloud Threats

- Misconfigured storage.
- Weak IAM.
- Data exposure.
- Insecure APIs.

IoT Threats

- Weak device security.
- Default passwords.
- Poor patch management.
- Large attack surface.

Supply Chain Threats

- Third-party compromise.
- Software dependency attacks.
- Vendor breaches.
- Trusted supplier compromise.

Module 3 - Information Assets & Data Protection

Information Assets

An **Information Asset** is anything that stores, processes, transmits, or supports valuable information required by an organization to achieve its business objectives. Although people often think only of documents or databases, information assets include much more than data itself. Hardware, software, cloud services, business applications, networks, intellectual property, contracts, and even employees' knowledge can all be considered information assets because they contribute to the organization's ability to operate.

From a cybersecurity and GRC perspective, information is one of the organization's most valuable business assets. If confidential customer information is stolen, financial records are altered, or critical systems become unavailable, the organization may suffer financial losses, legal penalties, reputational damage, and operational disruption. Therefore, identifying and protecting information assets is the starting point of every security program, risk assessment, and Information Security Management System (ISMS).

Almost every GRC activity begins with identifying organizational assets. During ISO 27001 implementation, risk assessments, business impact analysis, audits, and compliance reviews, the first question is usually **"What are we protecting?"** Without knowing the organization's assets, risks cannot be identified, controls cannot be selected, and security investments cannot be prioritized.

Asset Classification

Asset Classification is the process of categorizing information based on its value, sensitivity, and the level of protection it requires. Not all information has the same importance. Public marketing brochures do not require the same level of security as customer financial records or confidential business strategies. Classification helps organizations apply appropriate security controls according to the sensitivity of the information rather than protecting everything equally.

Asset classification is a fundamental requirement in ISO/IEC 27001 and many other security frameworks. As a GRC professional, you'll verify whether organizations have a classification policy, whether information is correctly classified, and whether appropriate controls are applied to each classification level.

Public

Can be shared with anyone.
Minimal protection required.

Internal

Intended only for employees.
Not publicly available.

Confidential

Sensitive business information.
Limited access.
Encryption often required.

Restricted / Highly Confidential

Highest level of protection.
Serious impact if disclosed.
Strict access controls.

Data Classification

Data Classification is the process of organizing data into categories based on its sensitivity, confidentiality, legal requirements, and business value. While asset classification focuses on the overall asset, data classification specifically focuses on the information contained within that asset.

The objective is to ensure that sensitive data receives stronger protection while allowing less sensitive information to remain easily accessible. Data classification enables organizations to apply appropriate security controls such as encryption, access restrictions, retention policies, and secure disposal methods.

Data protection regulations such as GDPR, HIPAA, and PCI DSS require organizations to identify and protect sensitive data. As a GRC professional, you'll frequently review data classification during compliance assessments, audits, privacy programs, and risk assessments.

Types of Data

- Personal Data
- Financial Data
- Health Information
- Intellectual Property
- Operational Data
- Public Information

Protection Methods

- Encryption
- Access Control
- Data Loss Prevention (DLP)
- Backup
- Secure Disposal
- Monitoring

Factors Considered

- Sensitivity
- Legal requirements
- Business impact
- Confidentiality
- Retention period

Data Lifecycle

Data does not remain in one state forever. It is created, used, stored, shared, archived, and eventually destroyed. This journey is known as the **Data Lifecycle**. Managing data throughout its entire lifecycle ensures that appropriate security controls are applied at every stage.

Many organizations focus only on protecting stored data, but data is equally vulnerable while being transmitted, processed, or disposed of. Effective lifecycle management ensures that information remains secure from creation until secure destruction.

Data lifecycle management supports compliance, reduces unnecessary data retention, minimizes legal risk, and improves overall information security. GRC professionals review lifecycle management during audits, privacy assessments, and records management programs.

Stages of Data Lifecycle

Create

Data is generated or collected.

Store

Data is saved in databases, servers, or cloud storage.

Use

Employees or systems access and process data.

Share

Data is transmitted internally or externally.

Archive

Data is retained for legal or business purposes.

Dispose

Data is securely deleted or destroyed.

Data States

Data exists in three different states during its lifecycle: Data at Rest, Data in Transit, and Data in Use. Each state faces different security risks and therefore requires different security controls.

Understanding data states helps organizations apply appropriate protections depending on where and how the data is being handled.

As a GRC professional, you'll frequently assess whether organizations adequately protect data in all three states. Security frameworks and compliance standards require organizations to secure stored information, transmitted information, and information actively being processed.

Data at Rest

Stored on hard drives, databases, cloud storage, USB devices.

Main control: Encryption, access control.

Data in Transit

Moving across networks.

Main control: TLS, VPN, secure communication protocols.

Data in Use

Being accessed or processed by users or applications.

Main control: Authentication, authorization, endpoint protection, memory protection.

Personally Identifiable Information (PII)

Personally Identifiable Information (PII) is any information that can directly or indirectly identify an individual. Some information identifies a person on its own, such as a passport number or Aadhaar number, while other information may identify someone when combined with other data, such as name, date of birth, and address. Because PII belongs to real individuals, organizations have both a legal and ethical responsibility to protect it from unauthorized access, disclosure, alteration, or loss.

Almost every organization today collects PII—banks, hospitals, universities, government departments, e-commerce companies, and employers all process personal information. If PII is exposed, individuals may suffer identity theft, financial fraud, privacy violations, or reputational damage. This is why data protection laws such as GDPR and India's Digital Personal Data Protection (DPDP) Act require organizations to handle personal information securely.

As a GRC professional, you'll frequently identify where PII is stored, who can access it, how it is protected, and whether the organization complies with privacy regulations. Many audits and

compliance assessments focus specifically on the protection of personal information.

Examples of PII

- Full Name
- Aadhaar Number
- PAN Number
- Passport Number
- Driving Licence
- Mobile Number
- Email Address
- Date of Birth
- Home Address
- Employee ID (in some cases)
- IP Address (depending on regulation)

Module 4 - Security Controls

Administrative Controls

Administrative Controls (also called Management Controls) are the policies, processes, procedures, and governance practices that define how security should be managed within an organization. These controls focus on people and processes rather than technology.

Administrative controls establish the organization's security expectations, assign responsibilities, define acceptable behaviour, and ensure that security activities are planned and monitored. They provide the foundation upon which technical and physical controls operate. Without proper administrative controls, technical solutions alone cannot create a secure environment.

Administrative controls are usually approved by senior management and apply across the organization.

Administrative controls form the backbone of Governance, Risk, and Compliance. During ISO 27001 implementation or an audit, you'll spend significant time reviewing policies, procedures, risk assessments, awareness programs, incident response plans, and management approvals—all of which are administrative controls.

Common Administrative Controls

- Information Security Policy
- Acceptable Use Policy

- Access Control Policy
- Risk Assessment Process
- Employee Background Verification
- Security Awareness Training
- Incident Response Plan
- Business Continuity Plan
- Vendor Management Process
- Change Management Process
- Security Standards
- Procedures and Guidelines
- Internal Audits
- Compliance Reviews

Technical Controls

Technical Controls (also called Logical Controls) are security measures implemented through technology to protect systems, networks, applications, and data. These controls automatically enforce security by restricting access, detecting threats, encrypting information, or monitoring system activity.

Unlike administrative controls, which rely on policies and people, technical controls operate through hardware and software. They help reduce human error and provide continuous protection.

Technical controls are often the most visible security measures within an organization, but they are effective only when supported by good governance and administrative controls. Most cyberattacks target technology. During risk assessments and audits, GRC professionals evaluate whether appropriate technical controls exist, whether they are configured correctly, and whether they effectively reduce organizational risk.

Common Technical Controls

- Firewalls
- Antivirus / Endpoint Protection
- Multi-Factor Authentication (MFA)
- Encryption
- Identity and Access Management (IAM)
- Intrusion Detection System (IDS)
- Intrusion Prevention System (IPS)
- Data Loss Prevention (DLP)
- Security Information and Event Management (SIEM)
- VPN
- Email Security Gateway
- Web Application Firewall (WAF)
- Patch Management
- Vulnerability Scanning

Physical Controls

Physical Controls are measures designed to protect people, buildings, equipment, and other physical assets from unauthorized access, theft, damage, or environmental threats. While cybersecurity often focuses on digital systems, physical security is equally important because attackers can bypass technical controls if they gain physical access to critical infrastructure. Physical controls protect data centers, offices, network equipment, servers, laptops, and other valuable organizational assets.

A perfectly secure network is still vulnerable if an attacker can walk into the server room and steal a hard drive. During audits, physical security controls are assessed alongside technical and administrative controls.

Common Physical Controls

- CCTV Surveillance
- Security Guards
- Biometric Access
- Smart Access Cards
- Visitor Management System
- Locked Server Rooms
- Fences
- Security Alarms
- Fire Suppression Systems
- Environmental Monitoring
- Cable Locks
- Secure Cabinets

Preventive Controls

Preventive Controls are security measures designed to **stop security incidents before they occur**. Their primary objective is to reduce the likelihood of threats successfully exploiting vulnerabilities. These controls act as the organization's first line of defense by preventing unauthorized actions, minimizing opportunities for attackers, and reducing overall risk.

Preventive controls are generally preferred because preventing an incident is more effective and less costly than detecting or recovering from one.

Risk treatment strategies often prioritize preventive controls because they reduce the probability of incidents. During audits and compliance assessments, organizations are expected to demonstrate that reasonable preventive controls have been implemented for significant risks.

Examples of Preventive Controls

- Strong Password Policies
- Multi-Factor Authentication
- Firewalls
- Encryption
- Access Control
- Security Awareness Training
- Secure Configuration
- Network Segmentation

- Secure Software Development
- Physical Access Restrictions

Detective Controls

Detective Controls are security measures that identify and report security incidents after or while they occur. Unlike preventive controls, they do not stop an attack directly. Instead, they provide visibility into suspicious activities so the organization can respond quickly and minimize damage.

The faster an incident is detected, the lower the potential business impact. Effective detective controls significantly reduce the time attackers remain undetected within an environment.

No organization can prevent every attack. Therefore, strong detection capabilities are essential. GRC professionals assess whether organizations have adequate monitoring, logging, alerting, and incident detection mechanisms in place.

Examples of Detective Controls

- Security Information and Event Management (SIEM)
- Intrusion Detection System (IDS)
- Security Monitoring
- Log Management
- Audit Logs
- Vulnerability Scanning
- File Integrity Monitoring
- Continuous Monitoring
- CCTV Monitoring
- Security Audits

Corrective Controls

Corrective Controls are security measures implemented **after a security incident has occurred** to eliminate the root cause, minimize damage, restore normal operations, and prevent the same incident from happening again. While preventive controls attempt to stop attacks and detective controls identify them, corrective controls focus on fixing the problem.

The objective is not just to recover from an incident but also to improve the organization's security posture by addressing weaknesses that allowed the incident to occur.

Every organization will eventually experience security incidents. What differentiates mature organizations is how effectively they recover and implement corrective actions. During audits and ISO 27001 reviews, you'll often verify whether incidents resulted in corrective actions and whether those actions were completed.

Examples of Corrective Controls

- Applying security patches
- Removing malware
- Restoring corrupted systems

- Password resets
- Reconfiguring firewalls
- Updating security policies
- Revising procedures
- Conducting root cause analysis
- Employee retraining
- Closing identified vulnerabilities

Compensating Controls

Compensating Controls are **alternative security measures** implemented when the primary or recommended control cannot be applied. They provide an equivalent level of protection by reducing the same risk through a different method.

Organizations may use compensating controls because of technical limitations, business requirements, budget constraints, legacy systems, or operational needs. However, compensating controls should reduce the risk to an acceptable level and must be properly documented and justified.

In real organizations, ideal security controls cannot always be implemented. As a GRC professional, you'll frequently encounter situations where compensating controls are necessary. During audits, you'll evaluate whether these alternative controls provide adequate protection.

When Used

- Legacy systems
- Technical limitations
- High implementation cost
- Business constraints
- Temporary security measures

Examples

- Manual log reviews instead of automated monitoring
- Additional network segmentation
- Increased security monitoring
- Restricted physical access
- Additional management approvals

Characteristics

- Temporary or permanent
- Documented
- Risk-based
- Approved by management

Deterrent Controls

Deterrent Controls discourage individuals from attempting unauthorized or malicious actions by creating the perception that such actions will be detected or have consequences. Unlike

preventive controls, which physically or technically stop attacks, deterrent controls influence behavior by increasing the perceived risk to attackers.

The goal is to convince potential attackers that attempting an attack is not worth the effort or risk.

Deterrent controls reduce the likelihood of intentional misuse by employees, visitors, and external attackers. While they may not stop every attack, they contribute to a stronger overall security posture when combined with other controls.

Examples of Deterrent Controls

- CCTV Cameras
- Warning Signs
- Security Awareness Programs
- Acceptable Use Policy
- Login Warning Banners
- Visible Security Guards
- Disciplinary Policies
- Visitor Badges
- Legal Notices

Benefits

- Discourages malicious behavior
- Improves employee awareness
- Reinforces organizational policies
- Supports compliance

Recovery Controls

Recovery Controls are measures designed to restore systems, data, and business operations after a security incident, disaster, or system failure. Their objective is to minimize downtime, restore critical services quickly, and ensure business continuity.

Recovery controls become active after corrective actions have addressed the immediate issue. They focus on returning the organization to normal operations while minimizing business impact.

Cybersecurity is not only about preventing attacks but also about ensuring organizations can recover quickly. Business Continuity Planning (BCP) and Disaster Recovery (DR) rely heavily on effective recovery controls. These concepts are central to ISO 22301, ISO 27001, and NIST CSF.

Examples of Recovery Controls

- Data Backups
- Disaster Recovery Plan (DRP)
- Business Continuity Plan (BCP)
- System Restoration
- Redundant Infrastructure
- Failover Systems

- Cloud Disaster Recovery
- Backup Power Supplies
- Recovery Testing

Objectives

- Restore services
- Minimize downtime
- Recover data
- Resume business operations

Control Effectiveness

Implementing security controls is only the first step. Organizations must also determine whether those controls actually reduce risk and operate as intended. This evaluation is known as **Control Effectiveness**.

A control is considered effective when it consistently achieves its intended objective, operates correctly, and reduces risk to an acceptable level. If a control exists only on paper or is poorly implemented, it provides little real security.

Control effectiveness is evaluated through monitoring, testing, audits, reviews, vulnerability assessments, penetration testing, and key performance metrics.

One of the core responsibilities of a GRC professional is not simply checking whether controls exist, but determining whether they are effective. This is a major focus during internal audits, ISO 27001 audits, SOC reports, and compliance assessments.

Methods to Evaluate Controls

- Internal Audits
- External Audits
- Control Testing
- Vulnerability Assessments
- Penetration Testing
- Continuous Monitoring
- Log Reviews
- KPI/KRI Monitoring
- Compliance Assessments

Questions to Ask

- Is the control implemented?
- Is it operating correctly?
- Does it reduce risk?
- Is it consistently followed?
- Does evidence support its effectiveness?

Possible Results

- Effective

- Partially Effective
- Ineffective
- Needs Improvement

Module 5 – Identity & Access Management (IAM)

Identity & Access Management (IAM)

Identity and Access Management (IAM) is the combination of policies, processes, and technologies used to create, manage, monitor, and remove user identities and their access to organizational resources. Its objective is to ensure that every user receives only the access required to perform their job and nothing more.

IAM manages the complete lifecycle of an identity—from the moment a new employee joins the organization until they leave. During this lifecycle, user accounts are created, permissions are assigned, access is modified when roles change, and accounts are disabled or deleted when employment ends.

IAM is not just an IT function; it is a governance function because it enforces organizational security policies, supports compliance, and reduces business risk.

Poor identity management leads to unauthorized access, privilege abuse, insider threats, and compliance failures. IAM is one of the most frequently audited domains under ISO 27001, NIST CSF, SOC 2, PCI DSS, and HIPAA.

As a GRC professional, you'll review:

- User provisioning
- Access approvals
- Privileged accounts
- Periodic access reviews
- User deprovisioning
- Segregation of Duties (SoD)

Objectives of IAM

- Verify user identities.
- Control access to resources.
- Prevent unauthorized access.
- Enforce Least Privilege.
- Maintain accountability.
- Support compliance.

IAM Lifecycle

1. Identity Creation
2. Identity Verification
3. Account Provisioning

4. Role Assignment
5. Authentication
6. Authorization
7. Access Monitoring
8. Periodic Access Review
9. Account Modification
10. Account Deactivation

Example:

A new Finance employee joins the company. HR raises a request, IT creates the account, assigns Finance-related permissions, enables MFA, reviews access every six months, and disables the account immediately after the employee resigns. This entire process is managed through IAM.

Identification

Identification is the process in which a user claims an identity to a system. At this stage, the system does not verify whether the user is genuine—it simply receives information indicating who the user claims to be.

Identification is always the first step before authentication. Without knowing who the user claims to be, the system cannot verify their identity or determine what permissions they should receive.

A claimed identity must be unique within the organization to prevent confusion and maintain accountability.

Every login process starts with identification. Accurate identification supports logging, auditing, accountability, and user management. If identities are duplicated or poorly managed, tracking user activities becomes difficult.

Common Identifiers

- Username
- Employee ID
- Email Address
- Customer ID
- Student ID
- Unique User Identifier (UUID)

Characteristics

- Unique
- Permanent where possible
- Assigned by the organization
- Used before authentication

Example

An employee enters mayur.patil@company.com on the Microsoft 365 login page. At this

stage, the employee has only identified themselves. The system has not yet verified that they are the legitimate owner of the account.

Authentication

Authentication is the process of verifying that a user is genuinely the person they claim to be. After identification, the system requests evidence that proves the claimed identity. This evidence may include passwords, biometrics, security tokens, smart cards, or one-time passwords.

Authentication prevents unauthorized individuals from accessing systems by requiring valid credentials before granting access.

Authentication answers the question:

"Can you prove you are who you claim to be?"

Weak authentication is one of the primary causes of unauthorized access and account compromise. Organizations therefore implement strong authentication mechanisms, particularly for sensitive systems and privileged accounts.

During audits, GRC professionals evaluate authentication policies, password requirements, MFA implementation, failed login controls, and authentication logs.

Example

After entering their corporate email, an employee enters the correct password and approves a login request through Microsoft Authenticator. The system confirms the employee's identity before allowing access.

Authorization

Authorization determines what an authenticated user is allowed to do after successfully proving their identity. Authentication confirms *who* the user is, while authorization determines *what resources they can access* and *what actions they can perform*.

Authorization is based on business requirements, job responsibilities, organizational policies, and the Principle of Least Privilege.

Organizations commonly assign permissions using roles rather than individual users, making access easier to manage and audit.

Many security incidents occur because users have excessive permissions rather than because authentication failed. Authorization ensures employees receive only the permissions necessary for their responsibilities.

During audits, authorization reviews focus on excessive privileges, segregation of duties, orphan accounts, and unauthorized access.

Authentication Factors

Authentication factors are the different categories of evidence used to verify a user's identity. Using multiple independent authentication factors significantly improves security because compromising one factor does not automatically compromise the account.

Authentication factors form the basis of Multi-Factor Authentication (MFA), which is considered one of the most effective defenses against credential theft.

Modern organizations increasingly require multiple authentication factors, particularly for remote access, cloud applications, privileged accounts, and financial systems. As a GRC professional, you'll verify whether authentication methods are appropriate for the organization's risk level.

Five Authentication Factors

Something You Know

- Password
- PIN
- Security Answer

Something You Have

- Mobile Phone
- Smart Card
- Hardware Token
- Authenticator App

Something You Are

- Fingerprint
- Face Recognition
- Iris Scan
- Voice Recognition

Somewhere You Are

- GPS Location
- Corporate Office Network

Something You Do

- Typing Pattern
- Signature Analysis
- Mouse Movement

Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) is a security mechanism that requires a user to provide **two or more different authentication factors** before access is granted. Instead of relying only on a password, MFA combines multiple independent factors, making it significantly harder for attackers to compromise an account.

A common misconception is that using two passwords is MFA. It is **not**. True MFA requires factors from different categories (e.g., password + fingerprint).

Even if an attacker steals a user's password through phishing or a data breach, they still cannot access the account without the second authentication factor.

Passwords are one of the weakest security controls because they can be guessed, stolen, reused, or leaked. MFA is considered one of the most effective controls for preventing unauthorized access.

Most organizations now require MFA for:

- Email accounts
- VPN access
- Cloud applications
- Administrative accounts
- Financial systems

Single Sign-On (SSO)

Single Sign-On (SSO) allows users to authenticate once and then access multiple applications without signing in separately to each one. Instead of remembering multiple usernames and passwords, users authenticate through a central identity provider.

SSO improves both security and user experience. Since users manage fewer passwords, they are less likely to reuse weak passwords or write them down.

SSO does not replace authentication—it centralizes it.

Modern organizations use dozens or even hundreds of applications. Managing separate credentials for each application increases administrative complexity and security risks.

SSO helps organizations:

- Simplify login.
- Improve productivity.
- Centralize authentication.
- Strengthen security when combined with MFA.

Principle of Least Privilege (PoLP)

The Principle of Least Privilege (PoLP) states that every user, application, or system should receive only the minimum permissions necessary to perform its required tasks—nothing more.

Users should never receive administrative or elevated privileges unless absolutely necessary. Restricting permissions reduces the potential damage if an account is compromised or misused.

PoLP is one of the most fundamental principles in cybersecurity and is recommended by virtually every security framework.

Excessive privileges are a common cause of data breaches. If attackers compromise an account with unnecessary permissions, they gain broader access to systems and data.

Objectives

- Minimize permissions.
- Reduce attack surface.
- Improve accountability.
- Support compliance.

Implementation

- Role-Based Access Control (RBAC)
- Regular Access Reviews
- Temporary Privileged Access
- Remove unnecessary permissions.
- Disable unused accounts.

Benefits

- Lower organizational risk.
- Easier audits.
- Better security governance.

Example

An HR employee needs access to employee records but does not need administrator rights on company servers. Granting only HR application access follows the Principle of Least Privilege.

Privileged Access Management (PAM)

Privileged Access Management (PAM) is the process of securing, controlling, monitoring, and auditing privileged accounts that have elevated permissions within an organization.

Privileged accounts have greater authority than standard user accounts. They can install software, change configurations, create users, access sensitive systems, and modify security settings. If these accounts are compromised, attackers can gain complete control of critical systems.

PAM solutions protect these high-risk accounts through strict controls, monitoring, and approval processes.

Privileged accounts are prime targets for cybercriminals because they provide extensive system access. Most security frameworks require organizations to identify, protect, and monitor privileged accounts.

During audits, PAM is often considered a high-risk area.

Examples of Privileged Accounts

- Domain Administrator
- Database Administrator
- Cloud Administrator
- System Administrator
- Network Administrator

- Root Account (Linux)

PAM Controls

- MFA
- Password Vault
- Session Recording
- Just-In-Time (JIT) Access
- Approval Workflow
- Activity Monitoring
- Privileged Session Monitoring

Example

A database administrator requests temporary elevated privileges to perform maintenance. After approval, access is granted for two hours and then automatically revoked. All administrator activities are recorded for audit purposes.

Access Review & Account Lifecycle

Access management does not end after creating a user account. Organizations must continuously review user access to ensure permissions remain appropriate throughout the user's employment. This process is known as the **Account Lifecycle**.

The lifecycle begins when an account is created and ends when it is permanently removed. During this period, user permissions may change due to promotions, department transfers, or project assignments.

Regular access reviews help identify excessive permissions, inactive accounts, orphan accounts, and unauthorized access.

A widely accepted industry practice is the **Joiner–Mover–Leaver (JML)** process:

- **Joiner:** Create the account and assign the correct access.
- **Mover:** Update access when the user's role changes.
- **Leaver:** Immediately disable and remove access when the user leaves the organization.

Many data breaches occur because former employees still have active accounts or current employees retain unnecessary permissions after changing roles. Proper lifecycle management reduces these risks and is a key requirement in ISO 27001, SOC 2, PCI DSS, and NIST.

Account Lifecycle

1. Account Request
2. Management Approval
3. Account Creation
4. Access Assignment
5. Periodic Access Review

6. Access Modification
7. Temporary Access Removal
8. Account Disablement
9. Account Deletion
10. Audit & Documentation

Access Review Checks

- Is access still required?
- Is the user's role correct?
- Are privileges excessive?
- Are inactive accounts disabled?
- Are orphan accounts removed?

Best Practices

- Review privileged accounts quarterly.
- Review standard user access at least annually (or more frequently for critical systems).
- Immediately disable accounts of terminated employees.
- Document all approvals and changes.

Example

An employee transfers from Finance to Human Resources. During the role change, Finance system access is removed, HR system access is granted, and the change is approved and documented. Six months later, an access review confirms the employee still has only the permissions required for the HR role.

Accounting

Accounting (also known as **Accounting, Auditing, and Accountability (AAA)**) is the process of **tracking, recording, and monitoring every action performed by a user after they access a system**. While Identification determines who the user is, Authentication verifies their identity, and Authorization determines what they can access, Accounting records **what they actually did**.

Accounting creates an audit trail by logging user activities such as logins, logouts, file access, configuration changes, failed login attempts, administrative actions, and other security-related events. These records help organizations investigate incidents, identify misuse, ensure accountability, and meet compliance requirements.

The primary goal of Accounting is to ensure that every action performed in a system can be traced back to a specific user or process.

Accounting is essential for audits, forensic investigations, compliance, and incident response. Without proper logging, organizations cannot determine who performed an action, when it occurred, or what was affected. Almost every security framework—including ISO 27001, NIST, PCI DSS, and SOC 2—requires organizations to maintain audit logs and monitor user activities.

Accounting Records

- Login and Logout Activities
- Successful and Failed Authentication Attempts
- File Access
- Database Queries
- Configuration Changes
- Privileged User Activities
- Command Execution
- Application Usage
- Security Events
- Administrative Changes

Objectives

- Maintain Accountability
- Support Audits
- Detect Suspicious Activities
- Assist Incident Response
- Meet Compliance Requirements

Best Practices

- Enable logging on critical systems.
- Protect logs from unauthorized modification.
- Synchronize systems using NTP for accurate timestamps.
- Regularly review audit logs.
- Retain logs according to organizational policy.

Example

A system administrator deletes several user accounts. The audit logs record the administrator's username, the exact time of the action, the affected accounts, and the originating IP address. During an investigation, these logs help determine exactly who performed the action.

Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) is an access control model where permissions are assigned to **roles**, and users receive permissions by being assigned to those roles. Instead of assigning permissions individually to every employee, organizations create roles based on job functions such as HR Manager, Finance Executive, System Administrator, or Auditor.

RBAC simplifies access management because when a user's job changes, administrators only need to change their assigned role rather than modifying numerous individual permissions.

RBAC is one of the most widely used access control models in enterprise environments because it is easy to manage, scalable, and aligns well with organizational structures.

Large organizations may have thousands of employees. Managing permissions individually becomes inefficient and error-prone. RBAC improves security, simplifies administration, supports Least Privilege, and makes access reviews significantly easier during audits.

Components

- Users
- Roles
- Permissions
- Resources

Advantages

- Easier Administration
- Consistent Permissions
- Faster User Provisioning
- Simplified Audits
- Supports Least Privilege

Limitations

- Less flexible for complex environments.
- Role explosion can occur if too many roles are created.

Attribute-Based Access Control (ABAC)

Attribute-Based Access Control (ABAC) is an access control model that grants or denies access based on **attributes** rather than predefined roles. These attributes may relate to the user, the resource, the requested action, or the surrounding environment.

Unlike RBAC, which focuses on job roles, ABAC evaluates multiple conditions before making an access decision. This allows organizations to implement highly flexible and context-aware access control policies.

ABAC is commonly used in cloud environments, Zero Trust architectures, and organizations requiring dynamic access decisions.

Modern organizations often need more than role-based access. For example, access may depend on location, device type, time of day, department, data classification, or security clearance. ABAC provides the flexibility needed for these complex environments.

Common Attributes

User Attributes

- Department
- Job Title
- Security Clearance
- Employment Status

Resource Attributes

- Data Classification
- File Owner
- Application Type

Environmental Attributes

- Time
- Location
- Device
- Network

Action Attributes

- Read
- Write
- Modify
- Delete

Advantages

- Highly Flexible
- Context-Aware
- Supports Zero Trust
- Fine-Grained Access Control

Example

An employee from the Finance department is allowed to access payroll data only if they are using a company-managed laptop, connected from the corporate network, and accessing the system during business hours. Access is determined by evaluating multiple attributes rather than just the user's role.

Zero Trust Basics

Zero Trust is a cybersecurity security model based on the principle of "**Never Trust, Always Verify.**" It assumes that no user, device, application, or network should be trusted automatically, whether they are inside or outside the organization's network.

Traditional security models assumed that users inside the corporate network were trustworthy. Zero Trust eliminates this assumption by requiring continuous verification for every access request.

Access is granted only after verifying identity, device health, permissions, location, and other security conditions. Even after access is granted, user activity is continuously monitored.

Modern organizations use cloud services, remote work, mobile devices, and third-party vendors. Traditional perimeter-based security is no longer sufficient. Zero Trust reduces the risk of unauthorized access, insider threats, lateral movement, and credential compromise.

Zero Trust is becoming a core strategy in frameworks such as NIST, Microsoft Security, Google BeyondCorp, and many enterprise security programs.

Core Principles

- Never Trust, Always Verify
- Verify Every Access Request
- Least Privilege Access
- Assume Breach
- Continuous Monitoring
- Strong Authentication
- Device Verification
- Micro-Segmentation

Benefits

- Reduces Insider Threats
- Limits Lateral Movement
- Improves Security Visibility
- Strengthens Cloud Security
- Supports Compliance

Best Practices

- Implement MFA.
- Apply Least Privilege.
- Continuously monitor user activity.
- Verify device compliance.
- Review access regularly.

Basic Foundation Notes
GRC Roadmap
Mr. Mayur Patil
Module 6 – Risk Fundamentals

What is Risk?

Risk is the **possibility that an event will occur which could affect an organization's objectives**. In cybersecurity, risk exists when a **threat has the opportunity to exploit a vulnerability**, resulting in harm to the organization.

A common misconception is that risk is the same as a threat. It is not.

- A **Threat** is something that can cause harm.
- A **Vulnerability** is a weakness.
- **Risk** is the possibility that the threat will exploit that weakness and create business impact.

Risk is measured not only by whether something can happen but also by **how likely it is to happen and how severe the consequences would be**.

Risk is always evaluated in relation to business objectives. If an event does not affect the business, it is generally not considered a significant business risk.

Risk is the heart of GRC.

Every activity you'll perform later revolves around risk:

- Risk Assessments
- Risk Registers
- ISO 27001
- NIST RMF
- Internal Audits
- Compliance Assessments
- Business Continuity
 - Vendor Risk
- Cloud Risk

A GRC professional doesn't ask:

"Is this system secure?"

Instead, they ask:

"What risks exist, how serious are they, and how should the organization manage them?"

Risk consists of

- Threat
- Vulnerability
- Likelihood
- Impact

Business Impact may include

- Financial Loss
- Data Breach
- Regulatory Fine
- Legal Action
- Reputation Damage
- Operational Downtime
- Customer Trust Loss

Risk can never become zero.

Organizations manage risk—they do not eliminate it completely.

Risk Formula (Risk = Likelihood × Impact)

Organizations need a consistent way to compare risks. The most common approach is to evaluate:

Risk = Likelihood × Impact

This doesn't always involve precise mathematics. Many organizations use qualitative scales (Low, Medium, High) or numerical scores (1–5).

Likelihood measures the probability that a threat will exploit a vulnerability.

Impact measures the severity of the consequences if the event occurs.

A risk with a high likelihood but low impact may require less attention than a low-likelihood event with catastrophic consequences.

Every risk assessment you'll perform will estimate these two factors.

Without evaluating likelihood and impact, organizations cannot:

- Prioritize risks.
- Allocate security budgets.
- Select appropriate controls.
- Make informed business decisions.

Likelihood Factors

- Existing vulnerabilities
- Threat activity
- Exposure
- Security controls
- Historical incidents

Impact Factors

- Financial damage
- Operational disruption
- Regulatory consequences

- Reputation loss
- Customer impact
- Safety impact

Typical Risk Matrix

Likelihood	Impact	Overall Risk
High	High	Critical
High	Medium	High
Medium	High	High
Medium	Medium	Medium
Low	Low	Low

Threat, Vulnerability & Risk Relationship

Threats, vulnerabilities, and risks are closely connected but represent different concepts.

A **Threat** is anything capable of causing harm.

A **Vulnerability** is a weakness.

A **Risk** exists when the threat has the opportunity to exploit the vulnerability.

Without a vulnerability, many threats cannot cause damage.

Without a threat, a vulnerability may never be exploited.

Risk exists only when both are present.

This relationship is the foundation of every cybersecurity risk assessment.

One of the biggest mistakes beginners make is treating threats and risks as the same thing. Professional GRC work always separates:

- Asset
- Threat
- Vulnerability
- Existing Controls
- Risk

You'll use this sequence repeatedly when building risk registers and conducting ISO 27001 risk assessments.

Risk decreases when

- Threats are reduced.
- Vulnerabilities are removed.
- Security controls are improved.

Risk Appetite

Risk Appetite is the **amount and type of risk an organization's senior management is willing to accept in pursuit of its business objectives.**

No organization can eliminate every risk. Doing so would be too expensive and may prevent the business from operating effectively. Instead, leadership decides how much risk is acceptable.

Risk appetite varies between organizations depending on their industry, legal obligations, business strategy, and regulatory environment.

Risk appetite guides decision-making throughout the organization.

It helps determine:

- Which risks should be accepted.
- Which risks require treatment.
- How much security investment is appropriate.
- Which projects align with business objectives.

As a GRC professional, you'll ensure that risk decisions align with the organization's approved risk appetite.

Low Risk Appetite

- Banks
- Healthcare
- Defense
- Critical Infrastructure

Higher Risk Appetite

- Startups
- Research Organizations
- Innovation-focused companies

Determined by

- Board of Directors
- Executive Management

Risk Tolerance

Risk Tolerance is the **acceptable level of variation around the organization's risk appetite**. While risk appetite sets the overall direction, risk tolerance defines the measurable limits that management is willing to accept before action becomes necessary.

Think of it this way:

- **Risk Appetite** = Overall willingness to take risk.
- **Risk Tolerance** = The specific boundaries within which that risk is acceptable.

Risk tolerance is usually expressed using measurable criteria such as downtime, financial loss, number of incidents, or system availability.

Risk tolerance helps organizations make consistent operational decisions.

Without defined tolerances:

- Teams may overreact to minor risks.
- Serious risks may be ignored.
- Different departments may make inconsistent decisions.

Risk tolerance supports governance by establishing clear thresholds for action.

Examples

- Maximum downtime = 2 hours
- Maximum financial loss = ₹5 lakh
- Maximum failed logins before account lockout = 5
- Maximum acceptable system availability = 99.9%

Defined by

- Senior Management
- Risk Committee
- Board (for critical risks)

Example

An online payment company has a **low risk appetite** for service disruptions. It sets a **risk tolerance** of no more than **15 minutes of unplanned downtime per month**. If downtime exceeds that limit, management must investigate and implement corrective actions.

Risk Capacity

Risk Capacity is the **maximum amount of risk an organization can absorb before its ability to operate is seriously threatened**. Unlike Risk Appetite, which reflects what management is willing to accept, Risk Capacity represents the organization's absolute limit based on its financial strength, operational resilience, legal obligations, and available resources.

Risk Capacity answers the question: **"How much risk can we survive?"**

An organization should never accept risks beyond its capacity. Even if management is willing to take more risk, exceeding the organization's capacity could lead to bankruptcy, regulatory action, or business failure.

Example

A startup may be willing to lose ₹10 lakh on a new product (Risk Appetite), but if a ₹2 crore cyberattack would force it to shut down, then ₹2 crore exceeds its Risk Capacity.

Risk Acceptance Criteria

Risk Acceptance Criteria are the predefined rules used to decide **whether a risk can be accepted or must be treated**. Organizations cannot treat every risk, so they establish thresholds that define acceptable and unacceptable levels of risk.

These criteria ensure risk decisions are consistent rather than based on individual opinions.

During risk assessments, every identified risk must have a decision. Risk Acceptance Criteria provide a standardized way to make those decisions and support governance.

Common Criteria

- Risk Rating
- Financial Impact
- Regulatory Impact
- Reputation Impact
- Business Criticality
- Likelihood

Typical Decision

- Low Risk → Accept
- Medium Risk → Monitor or Treat
- High/Critical Risk → Treat Immediately

Example

An organization decides that any risk with a score above 15 on its risk matrix cannot be accepted and must have a treatment plan.

Types of Risk

Organizations face different categories of risk. Cybersecurity is only one part of Enterprise Risk Management. Understanding these categories helps GRC professionals communicate risks effectively with business leaders.

When performing risk assessments, you must identify not only technical risks but also business, legal, operational, and strategic risks.

Common Types of Risk

- Cybersecurity Risk
- Information Security Risk
- Operational Risk
- Financial Risk
- Strategic Risk
- Compliance Risk
- Legal Risk
- Reputational Risk
- Third-Party/Vendor Risk
- Cloud Risk
- Privacy Risk

- Business Continuity Risk
- Physical Security Risk
- Technology Risk
- Project Risk

Example:

A cloud provider experiences a prolonged outage. This may create:

- Operational Risk (business disruption)
- Financial Risk (loss of revenue)
- Reputational Risk (customer dissatisfaction)
- Compliance Risk (failure to meet contractual obligations)

Risk Treatment Options

Once a risk is identified and assessed, the organization decides how to manage it. This decision is called **Risk Treatment**.

There are four standard risk treatment options used worldwide.

Risk treatment is one of the most important concepts in ISO 27001, ISO 31000, and NIST RMF. Every identified risk should have a documented treatment decision.

1. Avoid

Remove the activity causing the risk.

2. Reduce (Mitigate)

Implement security controls to lower likelihood or impact.

3. Transfer

Shift the financial impact to another party.

Examples:

- Cyber Insurance
- Outsourcing
- Service Contracts

4. Accept

Accept the risk because it falls within the organization's risk appetite.

Example

Risk: Web server vulnerable to attack.

- Avoid → Remove the public web service.
- Reduce → Install a Web Application Firewall and patch vulnerabilities.
- Transfer → Purchase cyber insurance.
- Accept → Accept the low residual risk after implementing controls.

Residual Risk

Residual Risk is the **risk that remains after security controls have been implemented**. No control completely eliminates risk, so some level of risk almost always remains.

Organizations must decide whether the remaining risk is acceptable.

Residual Risk is what management ultimately accepts. Auditors frequently verify whether residual risks have been documented, evaluated, and formally approved.

Exists after controls are applied.

Cannot usually be eliminated.

Compared against Risk Appetite.

May require continuous monitoring.

After implementing MFA, firewalls, and endpoint protection, phishing attacks are less likely but still possible. The remaining possibility of compromise is the Residual Risk.

Inherent Risk

Inherent Risk is the **level of risk that exists before any security controls or safeguards are applied**. It represents the natural exposure associated with an activity, process, or asset.

Comparing Inherent Risk and Residual Risk helps organizations understand how effective their controls are.

Most risk assessments begin by evaluating Inherent Risk and then reassess the risk after controls to determine Residual Risk.

Risk Ownership

Every identified risk must have a clearly assigned **Risk Owner**. The Risk Owner is the individual accountable for ensuring that the risk is managed appropriately, treatment decisions are made, and ongoing monitoring occurs.

Risk ownership is about accountability, not necessarily performing the technical work.

Without ownership, risks may be ignored, treatment plans may never be completed, and accountability becomes unclear.

Risk Owner responsibilities:

- Review risks.
- Approve treatment.
- Monitor progress.
- Accept residual risk when appropriate.
- Report risk status.

Risk Monitoring

Risk management is a continuous process. Risk Monitoring ensures that risks, controls, and treatment plans remain effective over time. As threats, technology, and business environments change, previously acceptable risks may become unacceptable.

Organizations that assess risks only once quickly become vulnerable. Continuous monitoring allows timely detection of new threats and ineffective controls.

Risk Monitoring includes:

- Periodic Risk Reviews
- Continuous Monitoring
- KPI and KRI Tracking
- Internal Audits
- Compliance Reviews
- Vulnerability Assessments
- Management Reporting

Risk Communication

Risk Communication is the process of sharing risk information with stakeholders so they can make informed decisions. Different audiences require different levels of detail.

Technical teams need technical information, while executives require summaries focused on business impact, cost, and strategic decisions.

Poor communication often results in delayed decisions, misunderstood risks, and ineffective governance. One of the key skills of a GRC professional is translating technical risks into business language.

Risk Communication should include:

- Description of the Risk
- Business Impact
- Likelihood
- Current Controls
- Recommended Treatment
- Risk Owner
- Current Status

Stakeholders

- Senior Management
- Board of Directors
- Risk Committee
- IT Teams
- Compliance Tea

Introduction to Enterprise Risk Management (ERM)

Enterprise Risk Management (ERM) is a structured approach to identifying, assessing, managing, and monitoring **all organizational risks**, not just cybersecurity risks. ERM integrates risk management into strategic planning and business decision-making.

Cybersecurity risk is one component of the organization's overall risk landscape.

As you progress toward senior GRC and CISO roles, you'll need to understand how cyber risks interact with operational, financial, legal, and strategic risks. ERM enables executives to make balanced decisions while achieving business objectives.

ERM Covers

- Strategic Risks
- Operational Risks
- Financial Risks
- Cyber Risks
- Compliance Risks
- Legal Risks
- Third-Party Risks
- Reputational Risks

Benefits

- Better decision-making.
- Improved resilience.
- Regulatory compliance.
- Stronger governance.
- Enterprise-wide visibility.

Example

A manufacturing company launching a new online platform evaluates not only cybersecurity risks but also financial, legal, operational, supply chain, and reputational risks before proceeding. This integrated approach is Enterprise Risk Management.

Module 7 – Cryptography

Encryption

Encryption is the process of converting **readable data (plaintext)** into an unintelligible form called **ciphertext** using an encryption algorithm and a key. Only an authorized party with the appropriate key can decrypt the ciphertext and recover the original information.

Encryption protects **confidentiality** by making data unreadable to unauthorized individuals. It can be applied to data **at rest**, such as databases and hard drives, and data **in transit**, such as information moving between a user's browser and a web server.

Encryption does not automatically guarantee that data is secure. Organizations must also properly manage encryption keys, select appropriate algorithms, control access to keys, and ensure encryption is correctly implemented.

Plaintext → Original readable information

Encryption → Process of converting plaintext into ciphertext

Ciphertext → Encrypted unreadable information

Decryption → Process of converting ciphertext back into plaintext

Key → Secret value used by the cryptographic algorithm

Data States

- **Data at Rest** → Stored data
- **Data in Transit** → Data moving between systems
- **Data in Use** → Data currently being processed

Common Enterprise Uses

- Full-disk encryption
- Database encryption
- File encryption
- Encrypted backups
- HTTPS/TLS
- VPN connections
- Cloud storage encryption

Symmetric Encryption

Symmetric encryption uses **the same secret key for both encryption and decryption**. The sender uses the key to encrypt the data, and the authorized recipient uses the same key to decrypt it.

Symmetric encryption is generally much faster than asymmetric encryption, making it suitable for encrypting large amounts of data. The major challenge is **secure key distribution**—both parties need access to the secret key without allowing an attacker to obtain it.

Common symmetric algorithms include **AES (Advanced Encryption Standard)**, which is widely used in enterprise environments.

Symmetric encryption is heavily used in real-world systems because of its speed and efficiency. GRC professionals will encounter it in:

- Database encryption
- Disk encryption
- Backup encryption
- Cloud storage
- TLS sessions
- VPNs

The important governance issue is not merely whether AES is being used, but whether the organization has appropriate **key management, access control, rotation, storage, and recovery procedures**.

Asymmetric Encryption

Asymmetric encryption uses a **pair of mathematically related keys**:

- **Public Key** – Can be shared publicly.
- **Private Key** – Must be protected by its owner.

Data encrypted with one key is associated with the other key in the pair. Asymmetric cryptography is particularly useful for secure key exchange, authentication, and digital signatures.

Unlike symmetric encryption, users do not need to share one secret key beforehand. However, asymmetric cryptographic operations are generally slower and more computationally expensive than symmetric encryption.

Common algorithms include **RSA** and **Elliptic Curve Cryptography (ECC)**.

Asymmetric cryptography is fundamental to modern secure communications and PKI. It enables technologies such as TLS certificates, digital signatures, and secure key exchange.

For GRC, the important areas include:

- Certificate management
- Private-key protection
- Cryptographic standards
- Key lifecycle management
- Algorithm strength
- Cryptographic compliance

Public Key

- Can be distributed.
- Used in encryption/signature verification scenarios.

Private Key

- Must remain confidential.
- Used in decryption/signing scenarios.

Common Algorithms

- RSA
- ECC

Major Uses

- Digital signatures
- Certificates
- Secure key exchange
- TLS
- Identity verification

Hashing

Hashing is the process of converting data of arbitrary size into a **fixed-length value called a**

hash or digest using a hash function. Unlike encryption, hashing is designed to be **one-way**: you should not be able to practically reconstruct the original data from the hash.

Hashing is primarily used to verify **integrity** and to securely store certain types of sensitive values, such as passwords when combined with appropriate password-hashing algorithms.

A small change to the original data should produce a substantially different hash value.

GRC professionals need to distinguish hashing from encryption because they serve different security purposes.

Encryption → Confidentiality

Hashing → Integrity

If a file's calculated hash changes, it indicates that the file's contents have changed.

For passwords, organizations should use dedicated password-hashing mechanisms such as **Argon2id, bcrypt, or scrypt**, rather than simply applying a fast general-purpose hash such as SHA-256.

Characteristics

- One-way function
- Fixed-length output
- Designed to detect changes
- Same input → same hash
- Small input change → significantly different hash

Common Hash Functions

- SHA-256
- SHA-384
- SHA-512

Avoid for modern security

- MD5
- SHA-1

These have known weaknesses and should not be selected for new security-sensitive applications.

Digital Signatures

A digital signature is a cryptographic mechanism used to provide **authenticity, integrity, and non-repudiation** for digital information. It uses asymmetric cryptography: the sender

creates a signature using their **private key**, and the recipient verifies it using the sender's **public key**.

Typically, the system first creates a hash of the message or document. The hash is then digitally signed using the private key. The recipient verifies the signature using the corresponding public key and compares the resulting hash with the document's calculated hash.

A digital signature is therefore different from encryption. **Encryption protects confidentiality**, while a digital signature primarily proves **who signed something and whether it was changed**.

Digital signatures are important in contracts, software distribution, certificates, financial transactions, regulatory submissions, and enterprise workflows. For GRC, they provide evidence that a document or transaction was approved by an authorized party and has not been altered afterward.

They are particularly relevant to:

- Document approval
- Electronic contracts
- Software integrity
- Regulatory submissions
- Authentication
- Audit evidence

Provides

- Authentication
- Integrity
- Non-repudiation

Uses

- Signed documents
- Software signing
- Digital certificates
- Secure transactions

Important distinction == Digital signature $\neq$ electronic signature.

An electronic signature can simply indicate someone's intent to sign. A digital signature uses cryptographic mechanisms to provide stronger technical assurance.

PKI

Public Key Infrastructure (PKI) is the **people, processes, technologies, policies, and**

cryptographic components used to create, manage, distribute, validate, and revoke digital certificates and public keys.

PKI establishes trust between entities that communicate digitally. It commonly relies on a **Certificate Authority (CA)** to issue certificates that bind an identity to a public key.

PKI is much broader than simply having certificates. It includes the entire lifecycle of certificates and keys, including issuance, validation, renewal, revocation, and policy enforcement.

PKI is fundamental to secure enterprise communication and identity management. It supports technologies such as:

- HTTPS/TLS
- VPN
- Smart cards
- Digital signatures
- Device authentication
- Secure email

For GRC, PKI introduces governance requirements around certificate issuance, ownership, expiration, revocation, private-key protection, and trust management.

Major Components

- Certificate Authority (CA)
- Registration Authority (RA)
- Digital Certificates
- Public/Private Keys
- Certificate Repository
- Certificate Revocation Mechanisms

Certificate Lifecycle

1. Request
2. Identity Validation
3. Issuance
4. Deployment
5. Monitoring
6. Renewal
7. Revocation
8. Expiration

Certificates

A digital certificate is an electronic credential that **binds an identity to a public key**. It is digitally signed by a trusted Certificate Authority (CA), allowing systems to verify that the public key belongs to the stated entity.

Certificates commonly use the **X.509** standard and contain information such as the subject, issuer, public key, validity period, serial number, and cryptographic signature.

Certificates are a major component of PKI and are heavily used for authentication and secure communications.

Incorrect certificate management can cause security incidents and operational failures. Expired certificates can take websites or applications offline, while compromised certificates or private keys can undermine trust.

For GRC, certificate management should therefore include:

- Ownership
- Inventory
- Expiration monitoring
- Renewal
- Revocation
- Key protection
- Approved certificate authorities

Certificate Information

- Subject
- Issuer
- Public Key
- Serial Number
- Valid From
- Valid Until
- Signature
- Key Usage
- Subject Alternative Name (SAN)

Common Types

- TLS/SSL certificates
- Client certificates
- Code-signing certificates
- Email certificates

Important Risks

- Expired certificate
- Compromised private key
- Incorrect certificate
- Untrusted CA
- Weak cryptographic algorithm

TLS/SSL

TLS (Transport Layer Security) is a cryptographic protocol used to secure communications over networks. It provides confidentiality, integrity, and authentication between communicating systems.

SSL (Secure Sockets Layer) is the older predecessor to TLS and is obsolete. Modern organizations should use current TLS versions rather than SSL.

When you visit a website using **HTTPS**, TLS protects the communication between your browser and the web server.

TLS generally combines asymmetric cryptography and symmetric cryptography. Asymmetric cryptography helps establish trust and securely establish session parameters, while symmetric cryptography is used for efficient protection of the actual communication.

TLS protects sensitive information while it travels across potentially untrusted networks.

It is essential for:

- Websites
- APIs
- Email
- VPNs
- Cloud services
- Application communication

For GRC, TLS configuration can become an audit and compliance requirement. Organizations may need to verify supported TLS versions, certificate validity, cryptographic algorithms, and configuration standards.

TLS Provides

- Confidentiality
- Integrity
- Server authentication
- Sometimes client authentication

HTTPS = HTTP protected using TLS

Important

- SSL 2.0 → Obsolete
- SSL 3.0 → Obsolete
- TLS 1.0 → Obsolete
- TLS 1.1 → Obsolete
- TLS 1.2 → Widely supported
- TLS 1.3 → Modern preferred version

TLS does not mean that the application itself is secure. An application can use HTTPS and still contain vulnerabilities.

Example

An employee accesses the company's HR portal through HTTPS. TLS encrypts the communication between the employee's browser and the HR server, helping protect credentials and employee information from network interception.

Key Management

Key Management is the process of **generating, storing, distributing, using, rotating, revoking, backing up, and securely destroying cryptographic keys throughout their lifecycle.**

Strong encryption is useless if the encryption keys are poorly protected. In many real-world incidents, the problem is not the cryptographic algorithm but improper key management.

Organizations therefore treat cryptographic keys as highly sensitive security assets and restrict access to authorized systems and personnel.

Key management is one of the most important practical aspects of cryptography from a GRC perspective. During an audit, it is not enough to ask:

"Is the data encrypted?"

You should also ask:

"Who controls the keys, where are they stored, who can access them, how are they rotated, and what happens if a key is compromised?"

Poor key management can completely undermine encryption controls.

Key Lifecycle

- Key Generation
- Key Distribution
- Key Storage
- Key Usage
- Key Rotation
- Key Backup
- Key Revocation
- Key Recovery
- Key Destruction

Security Controls

- Restrict key access.
- Separate key administrators from data administrators where appropriate.
- Monitor key usage.
- Rotate keys according to policy and risk.
- Protect private keys.
- Maintain key inventories.

- Securely destroy obsolete keys.

Enterprise Technologies

- Hardware Security Module (HSM)
- Key Management Service (KMS)
- Cloud Key Management Systems

Important GRC Evidence

- Cryptographic policy
- Key management procedure
- Key inventory
- Access records
- Rotation records
- Key-generation records
- Revocation records

Example

A company stores sensitive customer data in a cloud database encrypted using a managed KMS. Only authorized services can access the encryption keys, key usage is logged, and keys are rotated according to organizational policy.

Module 8 – Security Operations Basics

Logging

Logging is the process of **recording events and activities occurring within systems, applications, networks, and security devices**. Logs provide a historical record of what happened, when it happened, where it happened, and often which user or system performed the action.

Common logs include authentication logs, firewall logs, operating system logs, application logs, database logs, cloud logs, and administrative activity logs. Logs are usually generated automatically and stored centrally or locally for later analysis.

For GRC, logging is not simply a technical activity. It is a **security control and evidence source**. Organizations need defined requirements for what must be logged, who can access logs, how long they must be retained, and how logs are protected from unauthorized alteration.

Without logs, an organization may be unable to investigate incidents or prove that security controls are operating effectively.

Logs support:

- Incident investigation

- Security monitoring
- Audit evidence
- Compliance
- Forensics
- User accountability
- Detection of suspicious activity

Important log information can include:

- Timestamp
- User/account
- Source IP
- Destination
- Action performed
- Success/failure
- System/application
- Event type
- Device information

Important GRC considerations

- What events must be logged?
- How long are logs retained?
- Who can access them?
- Are logs protected from tampering?
- Are system clocks synchronized?
- Are critical logs centrally collected?
- Are logs regularly reviewed?

Monitoring

Security Monitoring is the continuous or periodic observation of systems, networks, applications, users, and security events to identify **suspicious activity, security incidents, control failures, and abnormal behavior**.

Logging records what happened; monitoring analyzes those events to determine whether something requires attention.

Monitoring can be performed using security tools, automated alerts, dashboards, rules, and human analysts. Modern organizations commonly monitor endpoints, networks, cloud environments, identities, applications, and privileged activity.

Security controls can fail, accounts can be compromised, and new threats can emerge after an environment has been secured. Monitoring provides ongoing visibility rather than relying only on periodic assessments.

For GRC, monitoring demonstrates that security controls are operating continuously and supports **continuous control monitoring** and compliance evidence.

Monitoring can detect:

- Suspicious logins
- Malware activity
- Privilege escalation
- Unusual network traffic
- Repeated failed authentication
- Unauthorized configuration changes
- Data exfiltration
- Policy violations

Monitoring sources

- Endpoints
- Firewalls
- Servers
- Applications
- Cloud platforms
- Identity systems
- Network devices

SIEM

SIEM stands for **Security Information and Event Management**. A SIEM platform collects and centralizes security-related logs and events from multiple sources, analyzes them, correlates related events, and generates alerts that may indicate security incidents.

Instead of security teams manually examining thousands of separate logs, SIEM provides a centralized view and uses correlation rules, detection logic, analytics, and dashboards to identify suspicious patterns.

SIEM is particularly important because individual events may appear harmless, but several events occurring together can reveal an attack.

SIEM is a major component of Security Operations Centers (SOCs). From a GRC perspective, SIEM supports:

- Security monitoring
- Incident detection
- Audit trails
- Compliance reporting
- Investigation
- Evidence collection

A GRC professional may evaluate whether critical systems are sending logs to the SIEM and whether alerting and retention requirements are being met.

Typical SIEM Process

Log Sources → Collection → Normalization → Correlation → Detection → Alert → Investigation → Response

Common Data Sources

- Firewalls
- Servers
- Active Directory
- Endpoints
- Cloud services
- Applications
- VPN
- Identity systems

GRC Considerations

- Log source coverage
- Retention period
- Alerting requirements
- Access controls
- Monitoring responsibilities
- Incident escalation
- Evidence preservation

EDR

EDR stands for **Endpoint Detection and Response**. It is a security technology designed to continuously monitor endpoint devices such as laptops, desktops, and servers, detect suspicious activity, and provide capabilities to investigate and respond to threats.

Unlike traditional antivirus, which primarily focuses on detecting known malicious software, EDR provides deeper visibility into endpoint behavior and can detect suspicious activity based on behavioral indicators and other telemetry.

EDR typically records information about processes, files, network connections, users, and system activity.

Endpoints are common targets for phishing, malware, ransomware, credential theft, and unauthorized access. EDR gives security teams visibility into what is happening on those devices.

For GRC, EDR can be treated as a security control whose effectiveness must be evaluated through coverage, configuration, alert handling, response capability, and reporting.

EDR commonly provides:

- Endpoint monitoring
- Threat detection
- Behavioral analysis
- Investigation
- Alerting
- Threat hunting
- Isolation/containment
- Response actions

GRC Questions

- Are all critical endpoints covered?
- Is EDR properly configured?
- Who investigates alerts?
- Are alerts responded to within defined timelines?
- Are exceptions documented?
- Is the agent tamper-protected?

XDR

XDR stands for **Extended Detection and Response**. It extends the detection and response approach beyond individual endpoints by correlating security telemetry across multiple security domains such as endpoints, email, identity, network, cloud, and applications.

EDR primarily focuses on endpoint visibility and response, while XDR provides a broader view across multiple security layers.

The goal is to identify relationships between events that may not be obvious when each security system is examined separately.

Modern attacks rarely remain within one system. An attacker may begin with phishing, compromise an identity, access a cloud application, and then move toward sensitive resources.

XDR helps security teams understand the **attack chain** rather than investigating isolated alerts.

For GRC, XDR can support centralized monitoring, incident response, detection coverage, and security operations maturity.

Possible XDR Data Sources

- Endpoint
- Email
- Identity
- Network
- Cloud
- Applications

EDR vs XDR

EDR

→ Primarily endpoint-focused

XDR

→ Cross-domain detection and correlation

Benefits

- Broader visibility

- Alert correlation
- Faster investigation
- Improved incident response
- Reduced isolated alerts

Vulnerability Management

Vulnerability Management is the **continuous process of identifying, assessing, prioritizing, remediating, and verifying security vulnerabilities** in an organization's systems, applications, devices, and infrastructure.

A vulnerability is a weakness that could potentially be exploited by a threat actor. Vulnerability management is therefore not simply "running a vulnerability scanner." It is a complete lifecycle: discover assets, identify vulnerabilities, assess their severity and business impact, prioritize them, remediate them, and verify that the vulnerability has actually been resolved.

A mature organization prioritizes vulnerabilities based not only on technical severity but also on factors such as asset criticality, exploitability, internet exposure, threat intelligence, data sensitivity, and business impact.

Unmanaged vulnerabilities are a major source of cybersecurity risk. Organizations may have thousands of vulnerabilities, but they cannot fix everything immediately. GRC helps ensure that vulnerabilities are prioritized according to business risk and that remediation requirements are governed and tracked.

Vulnerability management supports:

- Risk management
- Compliance
- Security assessments
- Audit
- Asset management
- Patch management
- Incident prevention

Vulnerability Management Lifecycle

Asset Discovery → Vulnerability Identification → Risk Assessment → Prioritization → Remediation → Verification → Reporting → Continuous Monitoring

Common Vulnerability Sources

- Vulnerability scanners
- Penetration testing
- Security researchers
- Vendor advisories
- Threat intelligence
- Configuration assessments

Important Factors

- CVSS severity
- Exploit availability
- Internet exposure
- Asset criticality
- Data sensitivity
- Business impact
- Existing compensating controls

GRC Evidence

- Vulnerability reports
- Remediation tickets
- Risk acceptances
- Exception records
- Scan results
- Remediation SLAs
- Management reports

Patch Management

Patch Management is the controlled process of **identifying, testing, approving, deploying, and verifying software and firmware updates** that address security vulnerabilities, bugs, performance problems, or other issues.

Patch management is closely related to vulnerability management but they are not the same thing. Vulnerability management identifies and prioritizes weaknesses; patch management is one of the major methods used to remediate vulnerabilities.

A mature patch management process balances security requirements with operational stability because deploying a patch without testing can potentially break critical business systems.

Unpatched systems are frequently targeted because attackers can exploit publicly known vulnerabilities. Organizations therefore need formal patch policies, defined remediation timelines, testing procedures, exception processes, and evidence that patches were successfully deployed.

For GRC, patch management is a key control that can be assessed during audits and compliance reviews.

Patch Management Lifecycle

Identify → Assess → Test → Approve → Deploy → Verify → Report

Patch Prioritization

- Critical security patches → Immediate priority
- High-risk vulnerabilities → Short remediation window
- Medium/Low risk → Scheduled remediation

Actual timelines should be based on organizational policy and risk.

Important Controls

- Patch inventory
- Defined SLAs
- Testing
- Change management
- Emergency patching
- Exception management
- Deployment verification
- Reporting

Incident Response

Incident Response is the structured process an organization follows to **prepare for, detect, analyze, contain, eradicate, and recover from cybersecurity incidents.**

An incident may include malware infection, ransomware, unauthorized access, data breach, phishing compromise, insider activity, or other events that threaten confidentiality, integrity, or availability.

Incident response should be governed by documented procedures, clearly defined roles, escalation requirements, communication processes, evidence-handling procedures, and recovery activities. The objective is not merely to "stop the attack" but to minimize business impact and restore secure operations.

No organization can guarantee that it will never experience a security incident. Therefore, resilience depends heavily on how effectively the organization responds when something goes wrong.

For GRC, incident response is important because you may evaluate:

- Incident response policies
- Response procedures
- Roles and responsibilities
- Incident records
- Regulatory reporting
- Lessons learned
- Testing and exercises
- Corrective actions

A commonly used incident response lifecycle is:

Preparation

→ Establish policies, tools, teams, training, and procedures.

Detection & Analysis

→ Identify and determine whether an event is actually an incident.

Containment

→ Limit the spread and business impact.

Eradication

→ Remove the root cause, such as malware or compromised credentials.

Recovery

→ Restore systems safely and monitor for recurrence.

Lessons Learned

→ Determine what failed, what worked, and what needs improvement.

Important GRC Documents

- Incident Response Policy
- Incident Response Plan
- Incident Response Procedures
- Incident Register
- Incident Report
- Lessons-Learned Report
- Corrective Action Plan
- Tabletop Exercise Report

Security Awareness

Security Awareness is the process of educating employees and other relevant personnel about **security responsibilities, threats, organizational policies, and expected security behavior.**

Employees are part of the organization's security control environment. Even strong technical controls can be undermined if users disclose credentials, click malicious links, mishandle sensitive information, or ignore security procedures.

A mature awareness program is continuous rather than a one-time training session. It should be based on organizational risks and should measure whether employee behavior is actually improving.

Human behaviour is a major factor in many security incidents. Security awareness reduces preventable mistakes and helps establish a security-conscious organizational culture.

For GRC, security awareness is particularly relevant to:

- Policy compliance
- ISO 27001
- Security culture
- Phishing risk
- Regulatory requirements
- Employee onboarding
- Audit evidence

Awareness Topics

- Phishing
- Password Security
- MFA

- Social Engineering
- Data Classification
- Clean Desk
- Remote Working
- Acceptable Use
- Incident Reporting
- Physical Security
- Privacy
- Removable Media

Program Components

- New employee training
- Annual awareness training
- Role-based training
- Phishing simulations
- Security campaigns
- Awareness communications
- Training records
- Effectiveness measurement

Useful Metrics

- Training completion rate
- Phishing click rate
- Phishing reporting rate
- Repeat failure rate
- Incident reporting rate

Security Metrics

Security Metrics are **measurable indicators used to evaluate the performance, effectiveness, efficiency, and risk level of an organization's security program.**

Metrics convert security activities into measurable information that can be used for decision-making. A GRC professional must understand that simply measuring activity is not enough. Good metrics should help management understand **risk, control effectiveness, trends, and business impact.**

Three concepts are particularly important:

Metric → A measurable value.

KPI (Key Performance Indicator) → Measures performance against an objective.

KRI (Key Risk Indicator) → Indicates increasing or decreasing risk exposure.

Executives cannot effectively manage cybersecurity using technical alerts alone. They need meaningful information about whether security objectives are being achieved and where risk is increasing.

Security metrics support:

- Executive reporting
- Risk management
- Control effectiveness
- Compliance
- Budget decisions
- Continuous improvement
- Audit

Examples of Security Metrics

- Number of critical vulnerabilities
- Average vulnerability remediation time
- Patch compliance percentage
- Security awareness completion rate
- MFA coverage
- Number of security incidents
- Mean Time to Detect (MTTD)
- Mean Time to Respond (MTTR)
- Number of overdue audit findings
- Number of open high-risk issues

Good Metric Characteristics

- Relevant
- Measurable
- Consistent
- Actionable
- Clearly defined
- Comparable over time

KPI Example

98% of critical systems patched within the defined SLA.

KRI Example

Number of internet-facing critical vulnerabilities increasing month over month.

GRC Principle

Do not report metrics simply because they are easy to collect. Report metrics that help management understand **security performance and organizational risk**.